



VULNERABILITY ASSESSMENT REPORT

IBM Altoro Mutual Demo Banking Application

Assessment Type	Passive Vulnerability Assessment
Target URL	https://demo.testfire.net
Assessment Date	07.06.2026

Prepared By:
Divya Sri K

TABLE OF CONTENTS

1. Confidentiality Statement	1
2. Disclaimer	1
3. Executive Summary	2
4. Assessment Scope	3
5. Methodology	3
6. Risk Severity Classification	4
7. Findings Overview	5
8. Detailed Findings	5
8.1 Missing Security Headers	5
8.2 Server Information Disclosure	6
8.3 Missing SameSite Cookie Attribute	7
8.4 Additional Web Service Exposure	8
8.5 Potential SQL Injection Indicators	9
8.6 Potential Reflected XSS Indicators	11
9. Positive Security Controls Observed	12
10. Recommendations Summary	13
11. Conclusion	13

1.CONFIDENTIALITY STATEMENT :

This report contains confidential and sensitive information related to the security posture of the assessed application. The contents of this report are intended solely for educational and assessment purposes as part of the Future Interns Cyber Security Internship Program.

Unauthorized disclosure, duplication, or distribution of this document without proper permission is discouraged.

2.DISCLAIMER :

The vulnerability assessment documented in this report was conducted using passive and ethical testing methodologies.

The assessment scope was strictly limited to publicly accessible pages and observable application behavior. No intrusive exploitation, denial-of-service attacks, brute force attacks, authentication bypass attempts, or unauthorized access activities were performed.

The findings presented in this report reflect observations identified during the assessment period and may not represent the complete security posture of the target application.

3.EXECUTIVE SUMMARY :

A passive vulnerability assessment was conducted on the IBM Altoro Mutual Demo Banking Application to identify publicly observable security weaknesses and configuration-related risks.

The assessment included:

- HTTP response header analysis
- Cookie security inspection
- Network exposure analysis using Nmap
- Passive web application analysis using OWASP ZAP

Multiple high, medium, and low-risk findings were identified related to:

- Security header misconfigurations
- Information disclosure
- Input handling weaknesses
- Additional service exposure

The assessment was performed strictly within ethical and read-only boundaries without conducting intrusive exploitation activities.

Severity	Findings Count
High	2
Medium	2
Low	2

4.ASSESSMENT SCOPE :

Target Application:

IBM Altoro Mutual Demo Banking Application

Target URL:

https://demo.testfire.net

Assessment Type:

Passive Vulnerability Assessment

Scope Limitations:

- Public-facing pages only
- Read-only assessment
- No brute force attacks
- No denial-of-service testing
- No authentication bypass attempts
- No malicious exploitation activities

Assessment Objective:

To identify publicly observable security weaknesses and provide remediation recommendations to improve the security posture of the application.

5.METHODOLOGY :

The assessment was conducted using passive and non-intrusive testing methodologies.

The following tools and techniques were used during the assessment:

1. Browser DevTools

- HTTP response header analysis
- Cookie inspection
- Client-side security review

2. Nmap

- Network exposure analysis
- Service identification
- Open port discovery

3. OWASP ZAP

- Passive application scanning
- Identification of potential web application vulnerabilities
- Endpoint enumeration

No intrusive exploitation or unauthorized activities were performed during the assessment.

6.RISK SEVERITY CLAFFICATION :

Severity	Description
High	• Vulnerabilities that may significantly impact CIA Triad • Need immediate remediation
Medium	• Vulnerabilities that may expose the application to moderate security risks • Need planned remediation
Low	• Minor security weaknesses or informational findings with limited impact • Need to monitor and improve

7.FINDINGS OVERVIEW :

ID	FINDING	SEVERITY
1	Missing Security Headers	Medium
2	Server Information Disclosure	Low
3	Missing SameSite Cookie Attribute	Low
4	Additional Web Service Exposure	Medium
5	Potential SQL Injection Indicators	High
6	Potential Reflected XSS Indicators	High

8.DETAILED FINDINGS :

8.1. Missing Security Headers :

Description :

The application response did not include commonly recommended HTTP security headers such as:

- Content-Security-Policy
- X-Frame-Options
- Strict-Transport-Security
- X-Content-Type-Options

Impact :

Missing security headers may increase exposure to:

- Clickjacking attacks
- MIME-type attacks
- Client-side injection risks

Risk Level: Medium

Evidence:

▼ Response headers	☐ Raw
Content-Type	text/html; charset=ISO-8859-1
Date	Mon, 25 May 2026 07:18:08 GMT
Server	Apache-Coyote/1.1
Transfer-Encoding	chunked

fig 1 : Missing Security Headers

Recommedation:

Implement standard **HTTP security headers** to strengthen browser-side security protections.

8.2. Server Information Disclosure :

Description:

The server disclosed backend technology details through HTTP response headers.

Observed Value:

Server : Apache-Coyote/1.1

Impact :

Public disclosure of server technologies may assist attackers in identifying potential platform-specific vulnerabilities.

Risk Level : Low

Evidence :

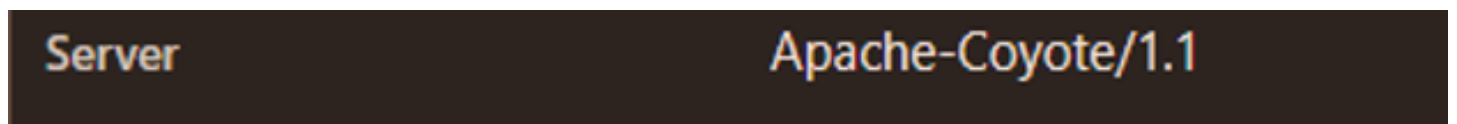


fig 2 : Server Information Disclosure

Recommendation :

Suppress unnecessary server and technology disclosure headers where possible.

8.3. Missing SameSite Cookie Attribute :

Description :

The session cookie did not explicitly define the SameSite attribute.

Impact :

Without the SameSite attribute, browsers may send session cookies during cross-site requests, potentially increasing exposure to Cross-Site Request Forgery (CSRF) attacks.

Risk Level : Low

Evidence :

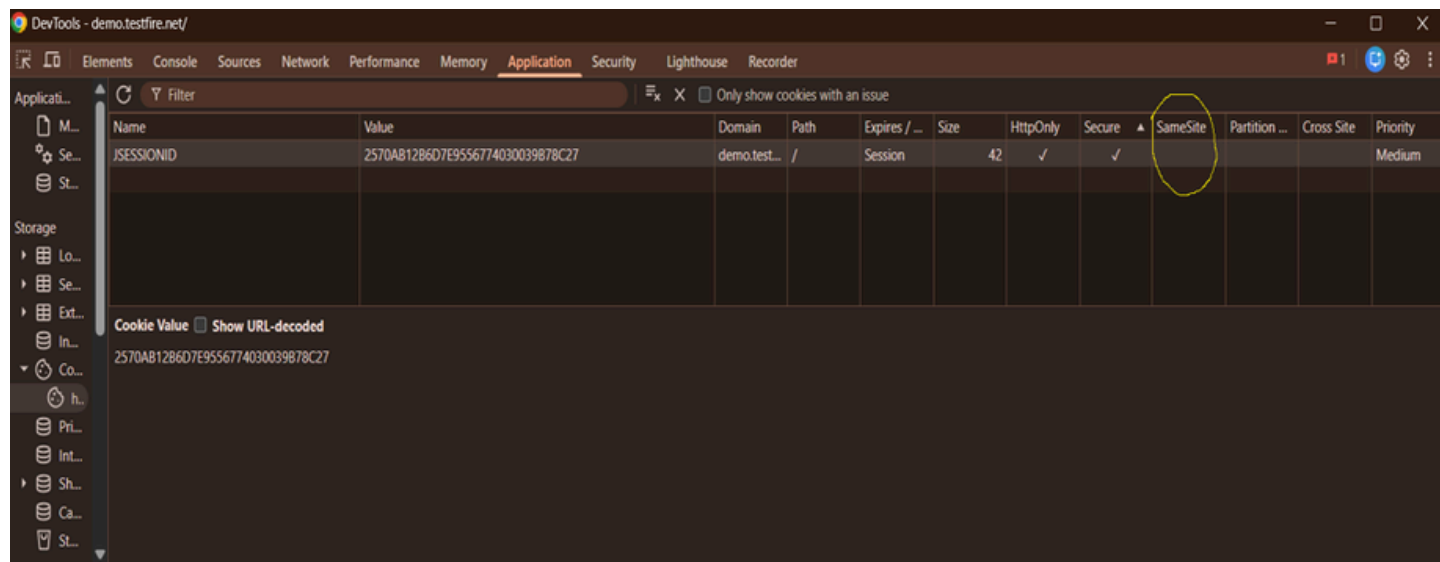


fig 3 : Cookie Security Review

Recommendation:

Configure session cookies using:

- SameSite=Lax (or) SameSite=Strict depending on application requirements.

8.4. Additional Web Service Exposure :

Description :

The assessment identified an additional publicly accessible HTTP service running on **TCP port 8080**.

Impact :

Exposed auxiliary services may increase the application's attack surface and introduce additional security risks if not properly secured or monitored.

Risk Level : Medium

Evidence :

```
C:\Users\varsh>nmap -sV demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-25 20:54 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.12s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
8080/tcp   open  http    Apache Tomcat/Coyote JSP engine 1.1
8443/tcp   closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 43.99 seconds
```

fig 4 : Nmap Service Enumeration

Recommendation :

Restrict unnecessary externally accessible services and ensure all publicly exposed services are securely configured and monitored.

8.5. Potential SQL Injection Indicators :

Description :

OWASP ZAP identified potential indicators of SQL Injection vulnerabilities in multiple application parameters during passive security analysis.

Affected Endpoints:

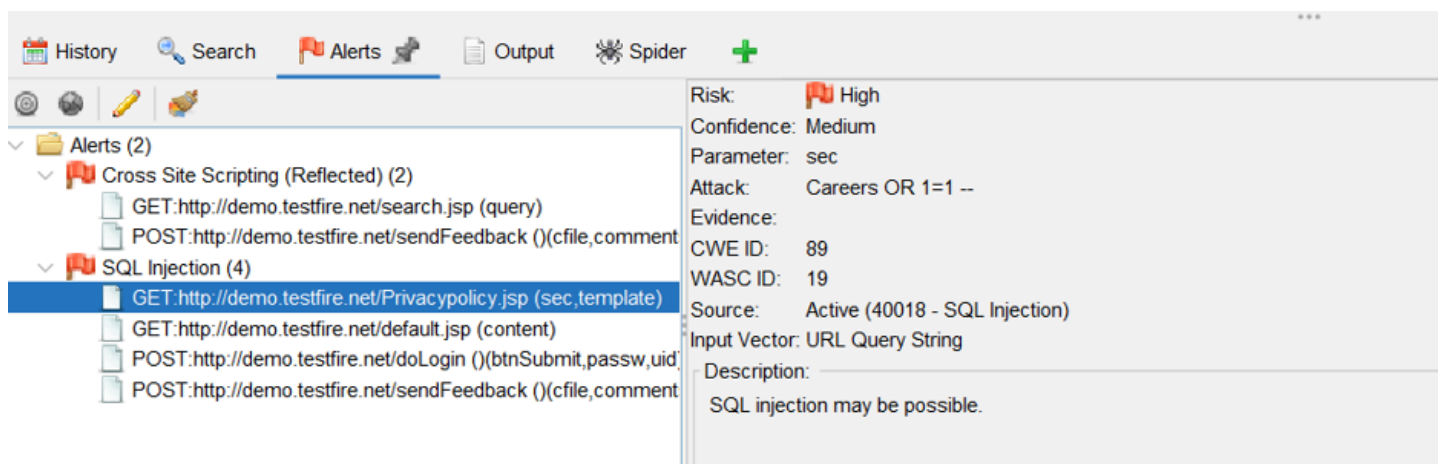
- /default.jsp
- /doLogin
- /Privacypolicy.jsp
- /sendFeedback

Impact :

SQL Injection vulnerabilities may allow attackers to manipulate backend database queries, potentially leading to unauthorized access to sensitive information.

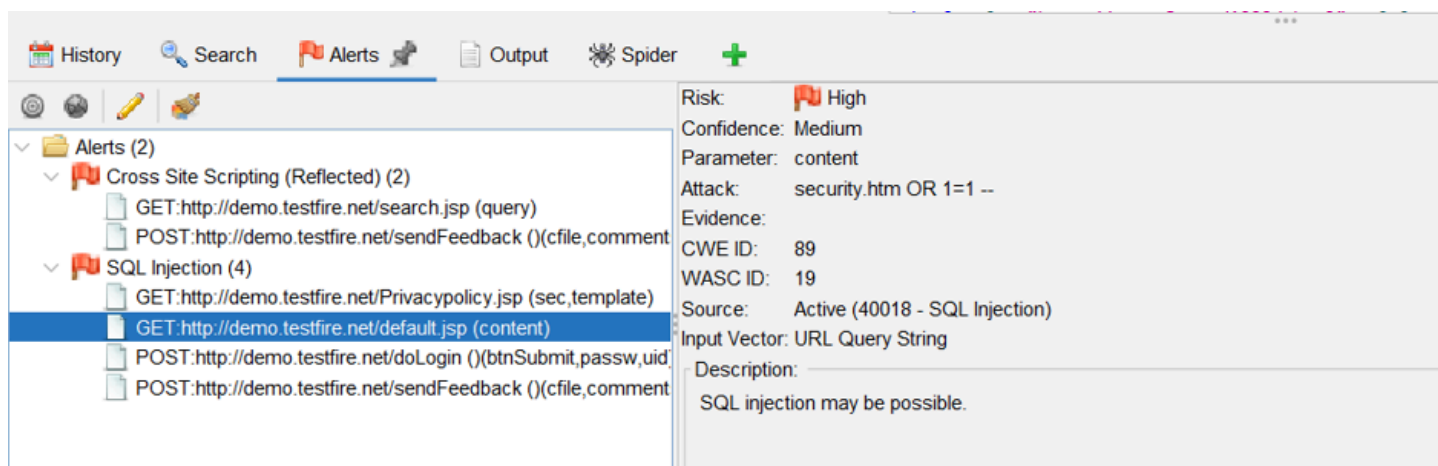
Risk Level : High

Evidence :



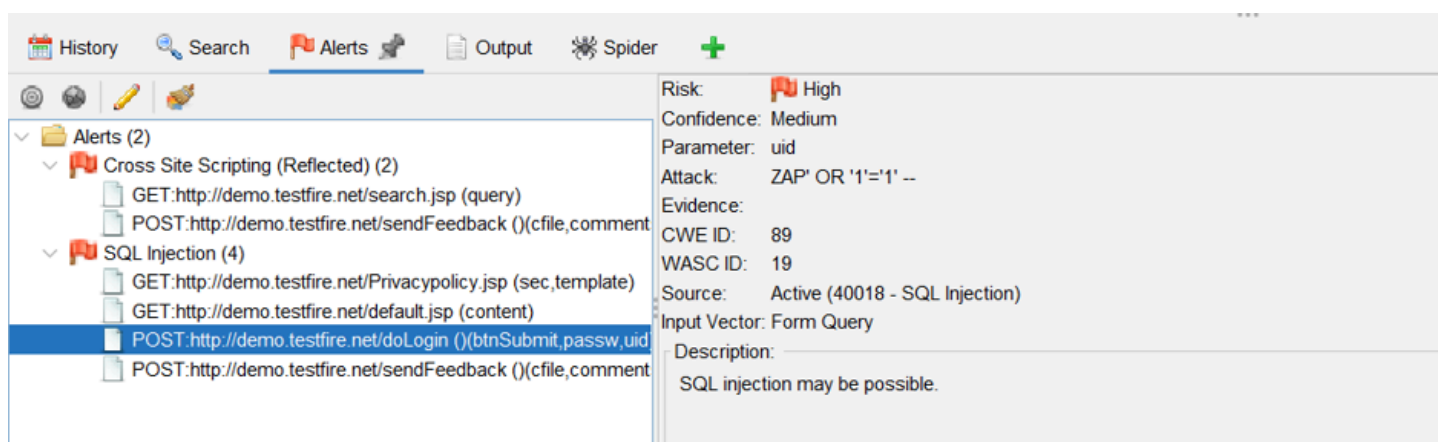
This screenshot shows the Testfire Alerts window with the 'Alerts' tab selected. The left sidebar lists alerts under 'Alerts (2)', including 'Cross Site Scripting (Reflected) (2)' and 'SQL Injection (4)'. The 'SQL Injection (4)' category is expanded, and the alert for 'GET:http://demo.testfire.net/Privacypolicy.jsp (sec,template)' is selected. The right pane displays the details for this alert:

- Risk:** High
- Confidence:** Medium
- Parameter:** sec
- Attack:** Careers OR 1=1 --
- Evidence:**
 - CWE ID: 89
 - WASC ID: 19
 - Source: Active (40018 - SQL Injection)
 - Input Vector: URL Query String
 - Description: SQL injection may be possible.



This screenshot shows the Testfire Alerts window with the 'Alerts' tab selected. The left sidebar lists alerts under 'Alerts (2)', including 'Cross Site Scripting (Reflected) (2)' and 'SQL Injection (4)'. The 'SQL Injection (4)' category is expanded, and the alert for 'GET:http://demo.testfire.net/default.jsp (content)' is selected. The right pane displays the details for this alert:

- Risk:** High
- Confidence:** Medium
- Parameter:** content
- Attack:** security.htm OR 1=1 --
- Evidence:**
 - CWE ID: 89
 - WASC ID: 19
 - Source: Active (40018 - SQL Injection)
 - Input Vector: URL Query String
 - Description: SQL injection may be possible.



This screenshot shows the Testfire Alerts window with the 'Alerts' tab selected. The left sidebar lists alerts under 'Alerts (2)', including 'Cross Site Scripting (Reflected) (2)' and 'SQL Injection (4)'. The 'SQL Injection (4)' category is expanded, and the alert for 'POST:http://demo.testfire.net/doLogin.jsp (btnSubmit,passwd,uid)' is selected. The right pane displays the details for this alert:

- Risk:** High
- Confidence:** Medium
- Parameter:** uid
- Attack:** ZAP' OR '1'='1' --
- Evidence:**
 - CWE ID: 89
 - WASC ID: 19
 - Source: Active (40018 - SQL Injection)
 - Input Vector: Form Query
 - Description: SQL injection may be possible.

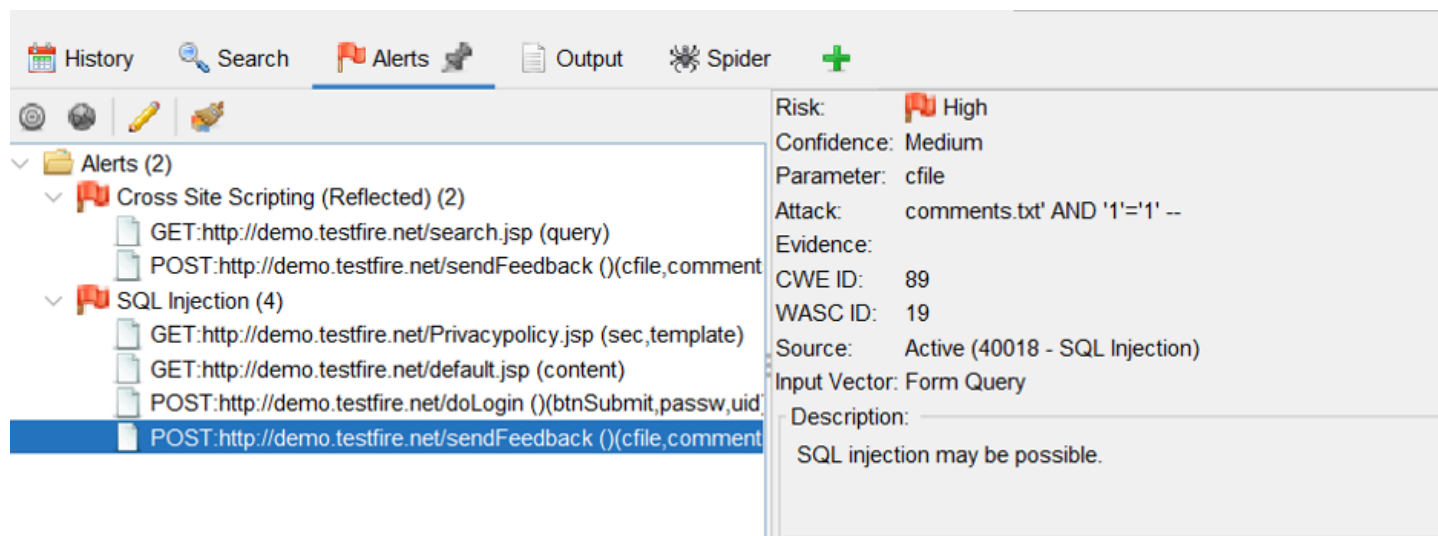


fig 5 : 4 SQL Injection Indicators from OWASP ZAP

Recommedations :

- Implement parameterized queries
- Use prepared statements
- Validate and sanitize user input
- Apply least-privilege database access controls

8.6. Potential Reflected Cross-Site Scripting (XSS) Indicators :

Description :

OWASP ZAP identified possible reflected Cross-Site Scripting behavior in user-supplied input parameters.

Affected Endpoints:

- /search.jsp
- /sendFeedback

Impact :

Reflected XSS vulnerabilities may allow malicious scripts to execute in a victim's browser, potentially leading to session theft or malicious redirection.

Risk Level : High

Evidence :

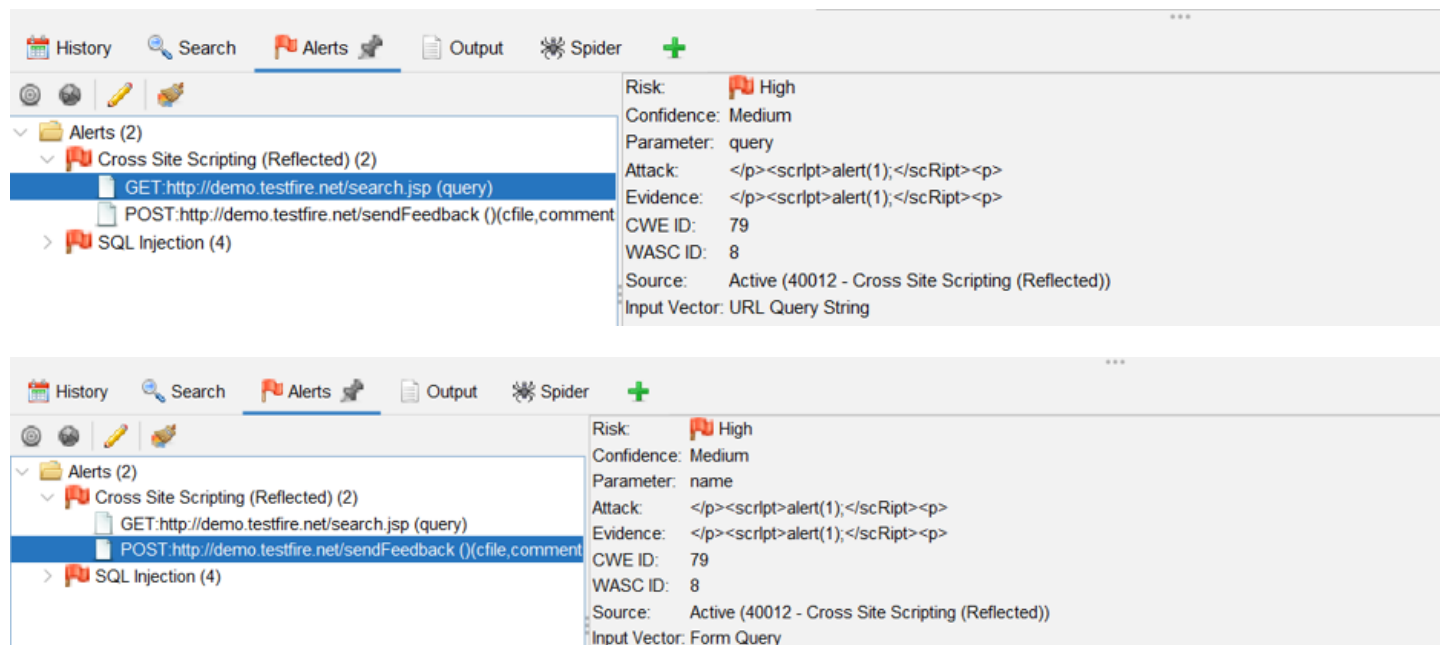


fig 6 : 2 Reflected XSS Indicators from OWASP ZAP

Recommendation:

- Validate and sanitize all user input
- Apply output encoding
- Implement Content Security Policy (CSP)
- Use secure input handling practices

9.POSITIVE SECURITY CONTROLS OBSERVED :

Security Control	Status
HTTPS Usage	Enabled
Secure Cookie Attribute	Enabled
HttpOnly Cookie Attribute	Enabled

10.RECOMMENDATION SUMMARY :

The following remediation actions are recommended to improve the security posture of the application:

- Implement missing HTTP security headers
- Suppress unnecessary server information disclosure
- Configure SameSite cookie attributes
- Restrict unnecessary exposed services
- Strengthen input validation mechanisms
- Use parameterized database queries
- Implement secure output encoding practices
- Conduct periodic vulnerability assessments

11.CONCLUSION :

- The passive vulnerability assessment identified several security observations across HTTP configuration, service exposure, cookie security, and input validation mechanisms.
- Two high-risk findings related to potential SQL Injection and Reflected Cross-Site Scripting indicators require priority review and validation. Medium-risk findings were associated with missing security headers and additional service exposure, while low-risk findings related to information disclosure and cookie configuration.
- Implementing the recommendations outlined in this report will strengthen the application's overall security posture and reduce potential attack surfaces. The assessment was conducted within a strictly ethical, read-only scope without performing exploitation activities.